

AUTENTICACIÓN WINDOWS vs. SQL SERVER

EN ENTORNOS UNIVERSITARIOS

Elegir el método de autenticación adecuado mejora la seguridad, facilita la administración y reduce riesgos en la gestión de bases de datos.

1. AUTENTICACIÓN WINDOWS

Acceso para Personal Académico/Interno
Utiliza cuentas de dominio institucional (Active Directory). Ideal para docentes, administradores y personal interno de la universidad.

Ventajas de Kerberos

- Autenticación mutua entre cliente y servidor.
- No se envían contraseñas por la red.
- Utiliza tickets cifrados con tiempo de vida limitado.
- Mayor resistencia a ataques como "pass-the-hash".

Single Sign-On (SSO)

El usuario inicia sesión una sola vez en su equipo institucional y puede acceder a los recursos de SQL Server sin volver a ingresar credenciales.

Ideal para:

- Red interna universitaria.
- Ambientes bajo dominio (Active Directory).
- Simplificar la administración de usuarios.

2. AUTENTICACIÓN SQL SERVER

Acceso para Consultores Externos
Usa cuentas propias de SQL Server. Recomendado para consultores, terceros o usuarios que no pertenecen al dominio institucional.

Políticas de Contraseñas Complejas

- Longitud mínima de 12 caracteres.
- Debe incluir mayúsculas, minúsculas, números y símbolos.
- Expiración periódica.
- Evitar reutilización de contraseñas.

¿Cuándo usarla?

- Acceso de consultores o proveedores externos.
- Aplicaciones o servicios que requieren conexión programática.
- Escenarios donde no existe integración con Active Directory.

Consideraciones:

- Mayor responsabilidad en la gestión de usuarios.
- Riesgo más alto si las contraseñas son débiles.
- Requiere políticas estrictas de seguridad.

3. PRÁCTICAS SEGURAS PARA MITIGAR ATAQUES DE FUERZA BRUTA

1. Habilitar Bloqueo de Cuenta

Configurar la política de bloqueo de cuentas para bloquear temporalmente al usuario después de varios intentos fallidos.

2. Limitar y Monitorear Conexiones

Monitorear intentos de inicio de sesión fallidos y limitar el número de conexiones por IP o por usuario en SQL Server.

3. Usar Autenticación Fuerte

Siempre que sea posible, preferir la Autenticación Windows. Si se usa SQL Server Authentication, aplicar contraseñas fuertes y MFA en aplicaciones web.

RECUERDA: La seguridad en SQL Server es un proceso continuo. Evaluar, auditar y fortalecer las configuraciones de autenticación protege la información académica y administrativa.

ARQUITECTURA DE EN LA BASE DE DATOS GRADOS Y TÍTULOS

Gestión de accesos basada en roles para seguridad, trazabilidad y organización de funciones.

1. ROLES POR ESQUEMAS DEL SISTEMA (SEGURIDAD POR MÓDULOS)

Cada esquema agrupa objetos lógicos (tablas, vistas, procedimientos) y tiene roles específicos con permisos definidos.

ESQUEMA	DESCRIPCIÓN	ROL PRINCIPAL	PERMISOS CLAVE
CATÁLOGO	Información maestra de catálogos y parámetros del sistema.	rol_catalogo	SELECT (lectura) Diccionario de servicios, instituciones Ej. Carrera, Facultad, Toca de Documento
ACADEMICO	Gestión de estudiantes, planes de estudio y parámetros académicos.	rol_academico	SELECT, INSERT, UPDATE en datos académicos Ej. Estudiantes, Planes, Cursos, Períodos académicos
TRÁMITE	Procesos y estados de trámites de grados y títulos.	rol_tramite	SELECT, INSERT, UPDATE en trámites Ej. OTVOTs, Act. Rev. Ej. Solicitudes, Estados, Requisitos, Aprobaciones
EVALUACIÓN	Evaluación de trabajos de investigación y exámenes de grado.	rol_evaluacion	SELECT, INSERT, UPDATE (act. en etapas de evaluación) Ej. Evaluadores, Actas, Calificaciones
DOCUMENTO	Gestión y almacenamiento de archivos y documentos del proceso.	rol_documento	SELECT, INSERT, UPDATE, DELETE de archivos y documentos del proceso Ej. Actas, Anexos, Constancias

Los roles se asignan a usuarios o grupos según su función en el proceso. Esto asegura la separación de responsabilidades y el acceso controlado a datos críticos.

2. ROLES ESPECÍFICOS PARA EVALUADORES DE TESIS

Los evaluadores (comités) requieren acceso limitado y controlado para consultar información y registrar sus observaciones.

ROL_EVALUADOR_TESIS

Permisos limitados para revisar trabajos de investigación asignados y registrar observaciones.

PERMISOS DE CONSULTA

- ✓ SELECT en lecturas
- ✓ Trabajos de investigación
- ✓ Evaluadores
- ✓ Planes de estudio
- ✓ Escenarios de Trabajo (sin editar)

PERMISOS DE REGISTRO

- ✓ INSERT en Observaciones
- ✓ INSERT/UPDATE en Evaluaciones (solo las propias evaluaciones)
- ✓ Opciones de contribución
- ✓ Valorización de documento

El acceso del evaluador está restringido únicamente a la información que le fue asignada.

3. PIRÁMIDE DE ROLES JERÁRQUICOS (SEGREGACIÓN DE FUNCIONES)

Los roles se organizan jerárquicamente para garantizar el nivel de acceso y responsabilidades.

NIVEL	ROL	ACCESO
NIVEL 1	ADMINISTRADOR	Acceso total y configuración del sistema • Control total sobre todos los módulos • Gestión de usuarios, roles y permisos • Auditoría y configuración de seguridad
NIVEL 2	SUPERVISOR	Supervisión y control operativo • Monitoreo y aprobación de actividades • Aprobación de trámites y evaluaciones • Consulta de reportes y registros
NIVEL 3	OPERADOR	Ejecución de tareas operativas • Registro, actualización y consulta segura • Registro, captura y validación de datos • Sin permisos de configuración del sistema

PRINCIPIOS APLICADOS

Mínimo Privilegio
Cada usuario accede solo a lo necesario para su función.

Segregación de Funciones
Las tareas críticas se dividen entre roles distintos.

Trazabilidad
Todos los accesos se registran para auditoría y control.

RECUERDA: Una arquitectura de roles bien diseñada protege la información, reduce riesgos y garantiza la integridad del proceso de grados y títulos.

HARDENING Y CONFIGURACIÓN SEGURA DE SQL SERVER EN PRODUCCIÓN

Buenas prácticas para reducir la superficie de ataque, proteger los datos y garantizar la estabilidad del servidor.

1. CONFIGURACIÓN DE CUENTAS DE SERVICIO

Principio de privilegios mínimos

Usar cuentas de servicio gestionadas por Microsoft (MSA/gMSA). Evita el uso de cuentas locales o credenciales con privilegios elevados.

Principio de privilegios mínimos
• Asignar solo los permisos necesarios para ejecutar SQL Server y SQL Server Agent.
• No agregar las cuentas a grupos locales como Administrators.
• Sin inicio de sesión interactivo.

Beneficios
• Mayor seguridad.
• Rotación automática de contraseñas.
• Menor impacto ante compromisos.

Cuentas recomendadas

Servicio SQL Server → Cuenta gMSA (Ej. DOMINIO\sqlservr)

SQL Server Agent → Cuenta gMSA (Ej. DOMINIO\sqlservr)

Recomendación adicional

- Asegurar que la cuenta gMSA tenga permisos NTFS mínimos sobre las rutas de datos, logs y backups.
- Registrar la cuenta del servicio en Active Directory.

2. PROTOCOLOS DE RED SEGUROS

Reducir la superficie de ataque en la capa de transporte

Deshabilitar Named Pipes
No es necesario en la mayoría de entornos y puede ser explotado localmente.

Forzar cifrado SSL/TLS
Cifrar todas las conexiones para proteger credenciales y datos en tránsito.

Cambiar el puerto por defecto
Evitar el uso del puerto 1433 (bien conocido) para dificultar escaneos automatizados.

Configuración recomendada

Icono	Configuración	Estado / Acción	Ejemplo
🚫	Named Pipes	Estado: Deshabilitado	—
🔒	TCP/IP	Estado: Habilitado	—
🔒	Cifrado	Forzar cifrado: Si (SSL/TLS)	—
🔑	Puerto	Cambiar puerto (ej. 51433)	—

- ➡ Pasos clave
- Deshabilitar Named Pipes desde SQL Server Configuration Manager.
 - Habilitar Force Encryption en SQL Server Configuration Manager.
 - Usar un certificado válido (emitido por una CA interna o pública).
 - Permitir el nuevo puerto en el Firewall del servidor y de red.

3. MONITOREO DE SERVICIOS CRÍTICOS

Usar vistas de sistema (DMVs) para detectar y prevenir problemas

El monitoreo continuo permite identificar cuellos de botella, bloqueos, alto consumo de recursos y sesiones inactivas.

DMVs esenciales para monitoreo

sys.dm_exec_requests: Muestra las solicitudes en ejecución actualmente (CPU, wait, tiempo, etc.).

sys.dm_exec_sessions: Lista todas las sesiones conectadas al servidor.

sys.dm_db_index_physical_stats: Nivel de fragmentación de índices para mantenimiento.

sys.dm_os_wait_stats: Muestra las esperas acumuladas del servidor (recursos en espera).

sys.dm_os_process_memory: Información de uso de memoria por el motor de SQL Server.

sys.dm_tran_locks: Bloqueos actuales (liti para detectar contención y bloqueos maliciosos).

Acciones recomendadas

- Revisar periódicamente sesiones, bloqueos y esperas.
- Crear alertas para umbrales críticos de CPU, memoria y disco.
- Implementar auditoría y registros extendidos (XE).
- Revisar y planificar mantenimiento preventivo.

EL CICLO DEL PERMISO EN SQL: GRANT, DENY Y REVOKE

Ejemplo práctico aplicado a la Oficina de Grados y Títulos

El control de permisos en SQL Server garantiza que cada usuario o rol solo acceda a lo que necesita para su función, protegiendo la integridad y confidencialidad de la información académica.

Objetivo
Aplicar el principio de mínimo privilegio para asegurar datos críticos como resoluciones, diplomas y expedientes.

1. GRANT

Permitir lectura a Operadores en datos de estudiantes.

EJEMPLO PRÁCTICO

-- 1. Crear rol para operadores

CREATE ROLE rol_operador;

-- 2. Agregar usuarios al rol

EXEC sp_addrolemember 'rol_operador', 'usuario_maria';

EXEC sp_addrolemember 'rol_operador', 'usuario_juan';

-- 3. Conceder permiso de lectura

GRANT SELECT ON dbo.Estudiantes TO rol_operador;

-- (Opcional) Limitar a vista específica

GRANT SELECT ON dbo.vw_Estudiantes_Basicos TO rol_operador;

RESULTADO

Los operadores pueden consultar la información de estudiantes, pero no modificarla.

VERIFICACIÓN RÁPIDA

SELECT * FROM fn_my_permissions (NULL, 'DATABASE');

2. DENY

Restringir de forma estricta la modificación de resoluciones y diplomas a personal no autorizado.

EJEMPLO PRÁCTICO

-- 1. Denegar modificación a operadores

DENY INSERT, UPDATE, DELETE ON dbo.Resoluciones TO rol_operador;

DENY INSERT, UPDATE, DELETE ON dbo.Diplomas TO rol_operador;

-- 2. (Opcional) Denegar a usuarios específicos

DENY INSERT, UPDATE, DELETE ON dbo.Resoluciones TO usuario_maria;

-- Nota: DENY prevalece incluso si el rol padre tiene permisos de escritura.

RESULTADO

Los operadores no pueden modificar resoluciones ni diplomas.

VERIFICACIÓN RÁPIDA

SELECT * FROM fn_my_permissions (NULL, 'DATABASE');

3. REVOKE

Revocar de forma limpia accesos temporales otorgados a auditores externos tras finalizar su período.

EJEMPLO PRÁCTICO

-- 1. Durante la auditoría, se otorga acceso

GRANT SELECT ON dbo.Reportes_Grados_Titulos TO auditor_externo;

-- 2. Al finalizar el período, revocar permisos

REVOKE SELECT ON dbo.Reportes_Grados_Titulos FROM auditor_externo;

-- 3. (Opcional) Quitar rol temporal

EXEC sp_drolemember 'rol_auditoria', 'auditor_externo';

RESULTADO

El auditor externo pierde el acceso a la información una vez finalizado su trabajo.

VERIFICACIÓN RÁPIDA

SELECT * FROM fn_my_permissions (NULL, 'DATABASE');

Resumen del ciclo del permiso

GRANT: Concede acceso necesario según la función del usuario.

DENY: Bloquea explícitamente acciones no permitidas.

REVOKE: Retira accesos temporales e innecesarios de forma segura.

Buenas Prácticas

- Aplicar el principio de mínimo privilegio.
- Documentar cada cambio de permisos.
- Usar roles en lugar de permisos directos.
- Revisar y auditar permisos periódicamente.
- Revocar accesos que ya no sean necesarios.

Un ciclo de permisos bien gestionado protege la información académica, asegura el cumplimiento y fortalece la confianza institucional.

Oficina de Grados y Títulos

PROTECCIÓN FÍSICA CON TRANSPARENT DATA ENCRYPTION (TDE)

Cifrado en reposo para proteger los archivos de datos y backups de la base de datos GradosTítulos ante accesos no autorizados.

¿CÓMO FUNCIONA TDE? FLUJO DE CIFRADO EN REPOSO

- Solicitud de lectura/escritura**
Una aplicación o usuario solicita leer o escribir datos en la base de datos GradosTítulos.
- SQL Server intercepta la operación**
El motor de SQL Server intercepta la operación antes de escribir los datos en disco.
- Cifrado con DEX (AES)**
Los datos se cifran usando la Database Encryption Key (DEK) con algoritmo AES.
- Escritura en disco**
Los datos cifrados se almacenan en los archivos .mdf y .ldf y en los backups (.bak). En disco, los datos son legibles sin la clave.
- Lectura desde disco**
Al leer, SQL Server obtiene la DEK y descifra los datos para entregarlos al motor.
- Entrega de datos al motor**
Los datos son descifrados y puestos a disposición de las aplicaciones y usuarios autorizados.

JERARQUÍA DE CLAVES EN TDE

- Service Master Key (SMK)**
Clave a nivel de instancia. Generada automáticamente por SQL Server. Cifra la Database Master Key (DMK) de cada base de datos.
- Database Master Key (DMK)**
Clave a nivel de base de datos. Creada dentro de GradosTítulos. Cifrada por la SMK. Protege el certificado de servidor.
- Certificado de Servidor**
Certificado almacenado en la base de datos maestra. Se usa para proteger la Database Encryption Key (DEK).
- Database Encryption Key (DEK)**
Clave simétrica única para GradosTítulos. Es la clave que cifra y descifra los datos en los archivos de datos y backups.

Si una de las claves se ve comprometida, las capas superiores siguen protegiendo las claves y los datos. Esta jerarquía asegura la confidencialidad de los datos en reposo.

¿QUÉ SE CIFRA CON TDE?

- Archivos de datos (.mdf): Se cifran todas las páginas de datos del archivo primario.
- Archivos de log (.ldf): Se cifran todas las entradas del registro de transacciones antes de escribirse en disco.
- Backups de la BD (.bak, .trn): Los backups son copias cifradas de los datos y logs.

Los datos permanecen cifrados desde que se escriben en disco hasta que son leídos por SQL Server.

PASOS PARA HABILITAR TDE EN GradosTítulos

- Verificar/Crear Certificado de Servidor en la base de datos maestra.
- Crear la Database Master Key (DMK) en GradosTítulos.
- Crear la Database Encryption Key (DEK) en GradosTítulos.
- Habilitar el cifrado de datos.

EN RESUMEN

TDE protege los datos en reposo cifrándolos con la clave única de GradosTítulos. Incluye al ser anexado a los archivos de datos y backups. La jerarquía de claves garantiza que, incluso si se anula a los archivos de datos, los datos permanecen legibles.

REQUISITOS: Protección en reposo es una capa esencial de seguridad. Combínala con control de accesos, auditoría y políticas de seguridad para una estrategia completa.

ALWAYS ENCRYPTED: PROTEGIENDO LOS DATOS SENSIBLES DEL TESISISTA

Cifrado en el lado del cliente para proteger la confidencialidad de los datos personales, incluso de administradores de la base de datos.

1. ¿QUÉ ES ALWAYS ENCRYPTED?

Always Encrypted permite cifrar datos sensibles en el lado del cliente (aplicación) antes de que se envíen a SQL Server. SQL Server almacena y procesa los datos cifrados sin tener acceso a las claves, por lo que nunca puede ver la información en texto plano.

2. DATOS SENSIBLES DEL TESISISTA

Ejemplos de información personal que debe protegerse:

- DNI
- Correo Electrónico
- Teléfono

3. TIPOS DE CIFRADO EN ALWAYS ENCRYPTED

CIFRADO DETERMINISTA

- El mismo valor siempre genera el mismo texto cifrado.
- Permite búsquedas y comparaciones de igualdad (=), JOIN, GROUP BY, índices.
- Útil para campos como DNI.

Ejemplo: DNI

Valor en texto plano	Valor cifrado (determinista)
71543210	0xA1B3C3D4E5F60789
71543210	0xA1B3C3D4E5F60789
72435678	0x9F8E7D6C5B4A3210

Permite buscar: DNI = 71543210

CIFRADO ALEATORIO

- El mismo valor genera textos cifrados diferentes cada vez.
- No permite búsquedas por igualdad.
- Máxima protección para datos altamente sensibles.
- Útil para campos como Correo y Teléfono.

Ejemplo: Correo Electrónico

Valor en texto plano	Valor cifrado (aleatorio)
maria.torres@uni.edu.pe	0x1B7E9C0A2D3F6481
maria.torres@uni.edu.pe	0xDC2D4E6F9A8C7C11
maria.torres@uni.edu.pe	0x7A13F2C84E5D868

No permite buscar por igualdad

4. ¿CÓMO VIAJAN LOS DATOS CIFRADOS (FLUJO DE EXTREMO A EXTREMO)?

- Aplicación del Sistema de Grados y Títulos**
El usuario ingresa o consulta datos (DNI, Correo, Teléfono).
- Cifrado en el cliente**
El driver de SQL Client cifra los datos usando la clave pública del Column Master Key.
- Datos viajan cifrados**
Los datos cifrados viajan por la red hacia SQL Server. Incluso un atacante no puede leer la información.
- Almacenamiento en SQL Server**
SQL Server almacena los datos cifrados en las tablas y realiza operaciones soportadas.
- Devolución de datos cifrados al cliente**
SQL Server devuelve los datos cifrados; el cliente los descifra con la clave privada.

5. ¿POR QUÉ EL DBA NO PUEDE VER LA INFORMACIÓN EN TEXTO PLANO?

Las claves privadas nunca salen del cliente/aplicación. El DBA no puede descifrar los datos aunque tenga acceso total al servidor.

6. DBA / ADMINISTRADOR

No tiene la clave privada, por lo que SQL Server devuelve los datos cifrados.

7. JERARQUÍA DE CLAVES (RESUMEN)

- Column Master Key (CMK)
- Column Encryption Key (CEK)
- Cifrado de datos
- Descifrado en cliente

8. BENEFICIOS CLAVE

- Protege datos sensibles incluso de administradores de la BD.
- Reduce el riesgo de fuga de información.
- Cumple con normativas de privacidad (Ley N° 29733, GDPR, ISO 27001).
- Protección transparente para las aplicaciones sin cambiar la lógica de negocio.

9. RECOMENDACIÓN

Usar Always Encrypted para DNI (determinista) y Correo/ Teléfono (aleatorio) en la base de datos GradosTítulos Uni. Reducir el riesgo de exposición de datos sensibles y fortalecer la privacidad.

SISTEMA INTEGRAL DE AUDITORÍA EN GRADOS Y TÍTULOS

Monitoreo, registro y análisis continuo para garantizar la trazabilidad, transparencia e integridad de los procesos académicos.

CENTRO DE MONITOREO Y AUDITORÍA

ESTADO DEL SISTEMA

AUDITORÍA ACTIVA
Todos los eventos están registrados.

Eventos hoy: 12,458

Alertas críticas: 3

EVENTOS POR CATEGORÍA

- Logins: 40%
- Permisos: 21%
- Datos/Registros: 17%
- Modificaciones: 17%

EVENTOS POR HORA (HOY)

EVENTOS CRÍTICOS RECIENTES

- Eliminación de eventos: 10:21
- Cambio de rol crítico: 09:47
- UPDATE en Tabla-Resumen: 08:12
- Intento de login fallido: 09:33
- GRANT de permisos: 08:55

AUDITORÍA ALMACENADA EN

Base de datos de auditoría inmutable.

Retención: 365 días

EVENTOS AUDITADOS

1. INICIOS DE SESIÓN (LOGINS)

Registra cada intento y éxito de inicio de sesión al sistema.

SE REGISTRA:

- Usuario
- Fecha y hora
- Dirección IP
- Resultado (Éxito/Fallo)
- Aplicación origen

2. CAMBIOS DE PERMISOS

Audita la modificación de roles, permisos y asignaciones.

SE REGISTRA:

- Usuario que realiza el cambio
- Tipo de cambio (GRANT, REVOKE)
- Permisos/Objetos afectados
- Antes y después del cambio
- Fecha y hora

3. CREACIÓN / ELIMINACIÓN DE USUARIOS Y OBJETOS

Controla la creación o eliminación de usuarios, roles, tablas, vistas, procedimientos y otros objetos.

SE REGISTRA:

- Tipo de objeto (Usuario, Rol, Tabla, etc.)
- Acción (CREATE / DROP)
- Nombre del objeto
- Usuario ejecutor
- Fecha y hora

4. MODIFICACIONES CRÍTICAS EN ESQUEMA TRAMITE

Registra operaciones (INSERT, UPDATE y DELETE) sobre datos críticos del esquema Trámite.

SE REGISTRA:

- Tipo de operación (INSERT, UPDATE, DELETE)
- Tabla y registro afectados
- Valores antes y después (cuando aplica)
- Usuario ejecutor
- Fecha y hora
- Aplicación origen

FLUJO DE AUDITORÍA

- ACCIÓN DEL USUARIO**
El usuario ejecuta una acción en el sistema.
- CAPTURE DEL EVENTO (AGENT SPECIFICATION)**
SQL Server captura el evento según las especificaciones de auditoría.
- REGISTRO EN ARCHIVO DE AUDITORÍA**
El evento se escribe en archivos de auditoría en disco.
- ALMACENAMIENTO Y CONSERVACIÓN**
Los registros se almacenan de forma segura y se gestionan con retención definida.
- ANÁLISIS Y REPORTES**
Los eventos se analizan y se generan reportes para control y cumplimiento.

¿POR QUÉ LA AUDITORÍA GARANTIZA TRAZABILIDAD E INTEGRIDAD ACADÉMICA?

- DETECCIÓN DE FRAUDES:** Permite identificar acciones inusuales o no autorizadas sobre datos académicos sensibles (boletines, resoluciones, documentos).
- TRAZABILIDAD COMPLETA:** Cada acción queda asociada a un usuario, hora y origen, permitiendo reconstruir el historial completo de cambios.
- INTEGRIDAD DE LOS DATOS:** Cualquier modificación indebida puede ser detectada y reportada, asegurando la veracidad de la información académica.
- CUMPLIMIENTO NORMATIVO:** Cumple con regulaciones de protección de datos, transparencia y control interno (Ley N° 29733, ISO 27001, buenas prácticas).
- RESPONSABILIDAD Y RENDICIÓN DE CUENTAS:** Promueve una cultura de responsabilidad al saber que todas las acciones quedan registradas y auditadas.

COMANDOS Y HERRAMIENTAS UTILIZADAS

- SQL Server Audit
- Extended Events (para auditoría avanzada)
- Almacenamiento en archivos seguros o en tabla
- Visor de Auditoría de SQL Server / SSMS
- Reportes y alertas automatizadas

EJEMPLO DE EVENTO REGISTRADO

```

{
  "event_name": "2025-05-23T18:21:14Z",
  "action_name": "GRANT",
  "object_name": "Trámite",
  "object_type": "Tabla",
  "object_id": "1",
  "object_schema": "Resoluciones",
  "server_name": "GradosTítulos",
  "ip_address": "193.168.16.25",
  "login_name": "sa",
  "application_name": "SISTEMA_GRADOS_TITULOS"
}

```

EN RESUMEN

La auditoría electrónica es la base para un sistema de Grados y Títulos confiable, transparente y resistente a fraudes, asegurando que cada decisión académica esté respaldada por datos íntegros y verificables.

AUDITAR HOY, PROTEGER SIEMPRE